ASSIGNMENT 2 – Software Measurement – 1 GQIM

System: Banking Platform

Formalize Measurement Goals

Primary Goal: Ensure data integrity and security across all banking operations to protect user assets and maintain regulatory compliance.

Sub-goals:

1) Transaction Accuracy- purpose
    a. Goal: Ensure all financial transactions are recorded correctly and reflect accurate balances.
    b. Environment: Online and mobile banking systems connected to the central transaction database.
    c. Constraints: Limited by network latency, API synchronization intervals, and third-party payment gateway reliability.
    d. Questions:
        i. Are transaction records error free?
        ii. Do user account balances reconcile after transactions.
    e. Entity: Transaction record
    f. Indicator: Transaction accuracy ratio
    g. Metrics: % of verified correct transactions; # of reconciliation error per day

2) Security Control:
    a. Goal: Make sure banking systems preserve confidentiality, integrity, and availability of sensitive data and transactions in line with regulations.
    b. Questions: Q1: How quickly are anomalies or breaches detected and corrected?

       Q2: How many data leakage incidents or policy violations are detected per reporting period?

       Q3: What is the average recovery time from system outages or cyber incidents?

    c. Entity: monitoring and detecting logs, incident response reports, and system uptime data.
    d. Purpose: Assess and strengthen the overall security posture of the banking platform by monitoring confidentiality, anomaly detection, and recovery effectiveness.

e. Indicator: **Data Leakage Incident Rate** – count and severity of leakage/policy violations.
-Anomaly Response Effectiveness – average time to detect and correct anomalies or breaches.
-Mean Time to Recovery – average service restoration time after outages or cyber incidents.

f. Metrics:
- % of incidents resolved within the required response time.
- Average time to detect and resolve anomalies or breaches.
- Number of confirmed data leakage incidents per month.

g. Environment: The operational banking environment, including production transaction systems, centralized monitoring platforms, incident response systems, and audit repositories.

h. Constraints: Accuracy of results depends on the reliability of monitoring and detection systems.
- Incident detection and recovery times vary with staff availability and incident complexity.
-Measurements must align with financial and data protection regulations.
-Reporting processes must maintain customer privacy and data confidentiality.

3) Access Security
   a. Goal: Ensure Only approved users and services can access banking systems and data. Give them just the access they need and require strong logins (like MFA) to prevent misuse and meet regulations.
   b. Question: Q1. What % of active users and services have effective MFA?
      Q2. What % of accounts hold only approved roles (least privilege)?
   c. Entity: Authentication factors IdP/IAM accounts.
   d. Purpose: Assess and improve compliance with strong authentication (ex. MFA) and least privilege role assignment.
   e. Indicator:
      - Access security compliance ratio (ASCR)- Single % gauge weekly trend.
      - MFA Coverage – % breakdown (users vs. service accounts)
   f. Metrics: % of active users/services with MFA enforced, % of accounts with only approved roles.
   g. Environment: Live banking system; metrics computed weekly from IdP/IAM, MDM, SIEM, and PAM, with HR as the source of truth for active users and role baselines; service accounts included.

h. Constraints: Results depend on accurate HR data and HR–IAM sync; we use existing logs or exports and must comply with MFA and least-privilege policies.

4) System Availability purpose
   a. Goal: Ensure that all banking transactions, account balances, and data processing operations are executed and recorded with a high degree of accuracy to maintain data integrity and prevent discrepancies in accounts
   b. Environment: Banking application operating in a secure, cloud-based environment. Real-time transaction processing with multiple concurrent users. Integration with third-party financial APIs and audit systems.
   c. Constraints: Must comply with banking regulations (PCI-DSS, GDPR). Limited downtime for maintenance and updates. High transaction volume may affect real-time accuracy checks. Accuracy validation must not impact system performance.
   d. Questions:
      i. How accurately are transactions being processed and reflected in user accounts?
      ii. How often do discrepancies occur between transaction logs and account balances?
   e. Entity: Transaction Processing Module, Account Management, Reporting, Data Accuracy, Computation Correctness, Transaction Consistency
   f. Indicator: Transaction Accuracy Rate (TAR), Data Consistency Index (DCI)
   g. Metrics: % of Correct Transactions, Accurate Account Balances, and Correct Automated Calculations

5) Compliance and Audit Readiness - purpose
   a. Goal: Ensure the platform meets financial regulatory requirements and maintains audit readiness
   b. Environment: Compliance monitoring systems, audit dashboards, and documentation repositories.
   c. Constraints: Regulatory reporting timelines, policy update frequency, and human audit response times.
   d. Questions:
      i. Are compliance controls tested regularly?
      ii. How many audit findings or non-conformities occur per cycle?
   e. Entity: Compliance reports and audit documentation
   f. Indicator: Compliance adherence score
   g. Metrics: % of controls passed in audits; # of non-conformities per audit cycle

Define Indicators & Measures

Indicator	*Measure*	*Collection Method*	*Interpretation*

Goal 1			
Data leakage incident rate	Number of confirmed data leakage incidents per reporting period	Security monitoring logs, audit reports, incident tracking systems	Lower = stronger controls, zero incidents expected
Anomaly response effectiveness	Average hours to detect and correct anomalies or breaches	Transaction logs, anomaly detection alerts, incident response reports	Lower = faster detection and correction
Mean time to recovery	Average time to restore services after outages or cyber incidents	System uptime monitors, recovery logs, IT operations reports	Lower = greater resilience and availability
Access Security Compliance Ratio (ASCR)	% principals meeting all controls	Weekly join of IdP directory, IAM role graph,	Higher = better; alert <95%; target ≥98%.
MFA Coverage	% users with effective MFA; % service accounts using non-password strong authorization	IdP policy & auth logs	Higher = better; gap pinpoints units/apps lagging.
Transaction Processing Accuracy	% of Correct Transactions (Valid Transaction / Total Transaction) * 100	Collected automatically from transaction logs afeter each batch or real time processing	>= 99%: Excellect Accuracy; minimal transaction errors 95-98%: Acceptable but monitor for potential issues < 95%: Critical; investigate transaction validation or processing logic immediately
Data Consistency Level	% of Accurate Account Balances (Accounts with zero discrepancy / total accounts) * 100	Periodic reconciliation scripts comparing transaction histories with account balances	>= 98%: Strong consistency and data integrity maintained 95-97%: Minor inconsistencies detected; audit review < 95%: High inconsistency; trigger root cause analysis
Compliance adherence score	% of controls passed	Compliance audit reports	Higher = more compliant
Compliance adherence score	# of Non-Conformities	Audit documentation	Lower = better compliance

Identify Triggers and Actions To Implement Measures

ANALYSIS→ DIAGNOSIS → ACTION

Indicator	*Trigger*	*Analysis*	*Diagnosis*	*Action*
GOAL1				
Data Leakage Incident Rate	Any confirmed leakage incident > 0	Review logs from data loss prevention tools and incident reports; classify severity and source.	Misconfigured access controls, improper data handling, or failed encryption policies.	Immediate incident response. Contain leakage, revoke risky access, apply fixes. Deadline: ≤7 days.

Anomaly Response Effectiveness	Average detection or resolution time > 24 hours	Compare anomaly timestamps to detection and resolution logs.	Delays are caused by ineffective monitoring rules, staff shortages, or unoptimized detection tools.	Escalate security operations; tune monitoring rules, add staffing or automation. Fix within 7–14 days.
Mean Time to Recovery	Outage recovery > 4 hours (critical services)	Examine uptime reports and incident response logs to measure service restoration timelines.	Root cause: lack of redundancy, delayed escalation, or inadequate recovery procedures.	Initiate resilience improvements, add redundancy, and update runbooks. Owners: IT Ops + Security. Fix ≤14 days.
Access Security Compliance Ratio (ASCR)	Alert: ASCR< 95 %. Watch: 95–98%.	Weekly: match the HR roster to login accounts, include permissions and sign-in logs, and report results by team/app.	Missing MFA or extra/incorrect roles caused the drop.	Alert: fix in 7 days—enable MFA, remove extra access, disable stale accounts, block legacy logins. Watch: fix in 14 days. Recheck: after fixes (mid-week for alerts). Owners: IAM/Security (data & fixes), App owner (changes), Compliance (monthly review).
MFA Coverage	Users: <98% MFA. Admins: <100% MFA. App/script accounts: <100% strong non-password auth.	Check last week's sign-ins against the policy and list users/apps missing MFA or using weak methods.	Some users/app accounts don't have MFA or still use legacy sign-ins.	Enforce MFA, block legacy logins, move app/script accounts to non-password auth, and verify next week. Owners: IAM/Security + App owner. Deadline: 7–14 days (risk-based).
GOAL- 4				
GOAL-5				

Implementation Plan

1. Transaction Accuracy:

2. Security Control:

Scope & cadence: Production systems, all transactions and sensitive data. Weekly monitoring, monthly review.
Data: Transaction logs, anomaly events, incident reports, uptime records.
Owners: Security Ops (detection), IT Ops (recovery), Compliance (audit).
Weekly loop: Collect logs → compute detection time, leakage count, recovery time → post report → open tickets → verify fixes next cycle.
Triggers: Any leakage = immediate response. Detection >24h = escalation. Recovery >4h = resilience action.

Outputs: CSV, dashboard, ticket list.
Success: All incidents resolved ≤7 days, anomalies detected ≤24h, outages recovered ≤4h.

3. Access Security:

Scope & cadence: Production, all users/admins/service accounts. Run weekly, review monthly.
Data: HR roster ,IAM (accounts/roles) and sign-in logs (MFA).
Owners: IAM/Security (data & fixes), App/Team owner (changes), Compliance (review).
Weekly loop: Pull data → compute ASCR & MFA Coverage → post by team/app → open tickets → verify next run (mid-week recheck for alerts).
Triggers & SLAs: ASCR <95% = 7 days, 95–98% = 14 days. MFA-Users <98%, Admins <100%, Service accts <100% strong auth → enforce MFA/block legacy/move off passwords, verify next week.
Outputs: CSV, small dashboard, ticket list.
Success: Targets met and alerts closed in <=7 days, watch items in <=14 days.

4. **System Availability:**

Scope & cadence: Production servers, database clusters, and online banking interfaces. Continuous monitoring with weekly performances reviews and monthly uptime audits.
Data: Server uptime logs, downtime incident reports, system health metrics, response time records, and alert notifications
Owners: IT Operations (monitoring & recovery), Infrastructure Team (maintenance), Compliance (uptime auditing)
Weekly loop: Collect uptime and latency data → compute uptime percentage and mean recovery time → generate availability report → open maintenance or incident tickets → verify and validate resolved cases before next cycle.
Triggers & SLAs: Uptime <99.5% = immediate investigation. Recovery time > 2 hours = escalate to Infrastructure Lead. Repeated downtime within the same week = root cause analysis initiated
Outputs: Dashboard reports, weekly CSV reports, ticket tracking list, and uptime trend charts.
Success: Maintain >=99.9% uptime monthly average, all outrages recovered <= 2 hours, and no repeated downtime for the same subsystem within a week.

5. **Compliance and Audit Readiness:**

Text placeholder for words to describe the implementation plan in paragraph format (and our table describes the steps)

Phase	*Activity*	*Responsible*	*Frequency*
Setup	Define metrics, thresholds, and log structure	Security, DevOps, Compliance Team	Once
Monitoring	Collect and analyze logs		Continuous
Analysis	Review anomalies and compliance reports	Security Analyst	Weekly
Review	Present findings to leadership	Compliance Officer	Monthly
Action	Apply remediations, patches and policy updates	DevOps, Compliance team	Ongoing

Summary

This GQIM plan strengthens the data integrity, confidentially, availability and compliance posture of the Smart Banking Platform. By measuring accuracy, integrity, access security, availability, and regulatory compliance, the system ensures secure operations, reliable data, and readiness for external audits. This will build and maintain customer trust and meet financial industry standards.